Data Protection Impact Assessment
The Council · AI Governance Playbook (Level 5 document, §4.6.1)

A DPIA assesses the data protection risks of an AI system before it is approved for deployment.

UK GDPR Article 35 requires a DPIA where personal-data processing is likely to result in a high risk to individuals' rights and freedoms. The Council separately requires DPIA screening for every AI use and normally a completed DPIA for High and Critical systems. The Service Owner completes the DPIA; the DPO gives independent advice and quality assurance; the accountable Controller/SRO decides whether processing may proceed (Playbook §4.6.1).

PROPOSED — legal review only; draft clarification, not an adopted or live Council policy change. The Article 35 test is statutory and independent of AGPI: Council screening and any internal full-template threshold do not change it. Article 35 requires a DPIA only when its statutory conditions are met; Article 36 prior consultation is conditional on the statutory high-risk circumstances remaining after mitigation. A Council DPIA template or score is not prescribed by either Article. Record the statutory screening conclusion and DPO advice separately from any internal requirement to complete the full template. Official texts: UK GDPR Articles 35 and 36 https://www.legislation.gov.uk/eur/2016/679/article/35 and https://www.legislation.gov.uk/eur/2016/679/article/36 ; Data Protection Act 2018, as amended https://www.legislation.gov.uk/ukpga/2018/12/contents .

1. System and Submission Details

System identity	System identity (name, owner, service area): held once in the AI Register (AIG-INV-04) under this AIR-ID; do not re-key here.
UC-ID / processing scope	Purpose/data/population; AGPI priority ___; risk tier ___.
AIR-ID	AIR-XXXX
Date started	
DPO assigned	

Use-specific processing — identify purpose, data, people, recipients and decision/action for this UC-ID. Assess necessity, proportionality, risks and mitigations per materially distinct use; cross-reference shared technical evidence, not conclusions.

2. Screening — Is a DPIA Required?

Statutory indicators (UK GDPR Art 35(3)): ☐ Systematic and extensive evaluation based on automated processing, including profiling, with legal or similarly significant effects ☐ Large-scale processing of special category data (Art 9) or criminal offence data (Art 10) ☐ Systematic monitoring of a publicly accessible area on a large scale

ICO list of processing likely to result in high risk (Art 35(4)): ☐ Innovative technology, including AI (in combination with at least one criterion from the European guidelines) ☐ Denial of service: decisions on access to services, opportunities or benefits using automated decision-making or special category data ☐ Large-scale profiling ☐ Data matching from multiple sources ☐ Targeting of children or other vulnerable individuals ☐ Other ICO-listed processing (biometrics, genetic data, invisible processing, tracking, risk of physical harm)

☐ Other processing likely to create high risk to rights and freedoms Council policy: ☐ High or Critical AI tier

DPIA required?	Yes / No — apply the Article 35/ICO threshold; document a No decision and DPO advice. Council policy may still require a DPIA.

3. Description of the Processing

Nature of the processing (what the AI does with personal data; data flows; inputs and outputs)

Scope (categories of data, volume, geographic and time extent, number of data subjects)

Context (relationship with data subjects, expectations, vulnerable groups, prior concerns)

Purpose (intended outcomes, benefits to the Council and to residents)

4. Necessity and Proportionality

Lawful basis (UK GDPR Art 6)	
Special category condition (Art 9), if applicable	
Criminal offence data condition (Art 10 / DPA 2018 s.10 and Sch 1), if applicable	
Record of processing (ROPA) reference	

Why is the processing necessary, and could the purpose be achieved another way?

How are data minimisation, accuracy, retention and data subject rights upheld?

5. Automated Decision-Making Safeguards

Complete this section where the system makes significant decisions about individuals based solely on automated processing. The DUAA widens the circumstances in which such decisions may be permitted, subject to the Article 22A to 22D safeguards; it does not give a public authority a new lawful basis. Recognised legitimate interests (Art 6(1)(ea)), like legitimate interests (Art 6(1)(f)), cannot be relied on by a public authority for processing in the performance of its tasks (UK GDPR Art 6(1), as amended); the DPO and Legal must confirm the basis for any processing outside those tasks and validate the lawful basis for both the underlying processing and the decision. The separate restriction for special category data remains (Art 22B): a significant decision based entirely or partly on special category data may be taken solely by automated means only if (a) the decision is based entirely on data for which the data subject has given explicit consent, or (b) the decision is necessary for entering into or performing a contract with the data subject, or is required or authorised by law, and Art 9(2)(g) (substantial public interest) applies. Under Art 22B(4), no solely automated significant decision may be taken where the processing for it relies wholly or partly on recognised legitimate interests (Art 6(1)(ea)). Record DPO and Legal advice. The DPIA must show how each safeguard operates in practice (Playbook §4.6.1).

PROPOSED — legal review only; draft clarification, not an adopted or live Council policy change. Apply Articles 22A–22D only where their statutory scope and conditions for solely automated significant decision-making are met; do not infer their application merely from AI use or a Council risk tier. Data (Use and Access) Act 2025, section 80, amends the UK GDPR provisions: https://www.legislation.gov.uk/ukpga/2025/18/section/80 . ICO guidance: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/automated-decision-making-and-profiling/ **Forthcoming statutory code: the Data Protection Act 2018 (Code of Practice on Artificial Intelligence and Automated Decision-Making) Regulations 2026 (SI 2026/425), in force 12 May 2026, require the ICO to prepare a statutory code of practice on AI and automated decision-making, including children's personal data. Until the code is issued, apply current ICO guidance; once it is issued, the DPO reviews this section and the DPIA screening against it (AIG-AIMS-05 REQ-056, CHG-014). Proposed — for Council confirmation.**

Does the system make significant decisions based solely on automated processing?	Yes / No — if No, mark this section not applicable
Is special category data involved in those decisions?	Yes / No — if Yes, the separate special-category restriction and conditions apply; obtain DPO/Legal advice

How are individuals informed that a significant decision has been taken based solely on automated processing?

How can individuals make representations about the decision?

How is meaningful human intervention available, and who provides it?

How can individuals contest the decision?

6. Consultation

DPO advice requested and recorded?	Yes / No — date and advice reference
Data subjects / representatives consulted?	Yes / No — summary
Processors / suppliers consulted?	Yes / No

7. Risks to Rights and Freedoms

Score each risk: Likelihood (Low/Med/High) × Severity (Low/Med/High). Add measures to reduce each risk and the residual outcome.

Risk to individuals	Likelihood	Severity	Mitigation measure	Residual

8. Outcome, DPO Advice and Controller Decision

Residual risk after measures	Low / Medium / High
DPO advice on whether processing can proceed	Proceed / Proceed with conditions / Do not proceed / Further information required
Conditions or actions required	
Unmitigated high risk remains?	Yes / No — if Yes, processing must not begin
Article 36 ICO prior consultation	Required / Not required / Completed — reference, date and outcome
Controller/SRO decision	Proceed / Proceed with conditions / Do not proceed / Await ICO consultation

The DPO records independent advice on the DPIA and whether the processing can proceed. The Controller/SRO remains accountable for the decision. If unmitigated high risk remains, processing must not begin until the ICO has been consulted under Article 36 and the consultation outcome has been addressed.

DPO name	
DPO advice confirmation / signature	
Date	
Service Owner name	
Service Owner signature	
Date	
Controller/SRO name	
Controller/SRO decision / signature	
Decision date	

Document control
Administrative control record. This artefact remains a working draft until formally approved.

Field	Controlled value
Document ID	AIG-ASS-05
Version	1.6 draft
Status	Draft for Council review
Document owner	Data Protection Officer
Approving body	Pending — competent Council authority under confirmed Constitution / Scheme of Delegation; AI Assurance Board provides assurance and is not presumed to hold approval authority.
Approval date	Not yet approved
Effective date	Not yet effective
Next review date	To be set on approval: 12 months after the effective date, or sooner following material change

Field	Controlled value
Classification	OFFICIAL

Change history

Version	Date	Change summary	Owner
1.0 draft	6 August 2026	Document-control baseline established following full-suite quality assurance; no substantive content change.	Data Protection Officer
1.1 draft	14 September 2026	DUAA legal-currency update: tightened the solely-automated decision wording and added the public-authority lawful-basis caution (recognised legitimate interest is not a general basis for public tasks). Special-category and safeguard requirements unchanged.	Data Protection Officer
1.2 draft	29 September 2026	QA remediation — applied findings QA-076, QA-080, QA-160, QA-185, QA-200, QA-221 (see QA change log). The v1.1 entry describes wording since corrected at v1.2. Final tidy-up: self-referencing cross-reference removed from the standards row(s) REQ-033.	Data Protection Officer
1.3 draft	30 September 2026	v3.9.1: standards cross-reference note updated to the 54-entry requirement inventory (AIG-AIMS-05 REQ-054, Civil Contingencies Act 2004, added).	Data Protection Officer
1.4 draft	1 October 2026	v3.9.3: standards cross-reference note cites the 55-entry requirement inventory (AIG-AIMS-05 REQ-055, NIST AI 600-1 Generative AI Profile, added).	Data Protection Officer
1.5 draft	2 October 2026	v3.9.5: standards cross-reference note cites the 56-entry requirement inventory (AIG-AIMS-05 REQ-056, SI 2026/425 ICO statutory code of practice on AI and automated decision-making, added). Section 5 adds a pointer to the forthcoming ICO statutory code on AI and automated decision-making (SI 2026/425) and the standards cross-reference lists REQ-056. Proposed — for Council confirmation.	Data Protection Officer
1.6 draft	12 October 2026	v3.9.10: standards cross-reference note cites the 58-entry requirement inventory (AIG-AIMS-05 REQ-057 DAMA-DMBOK and REQ-058 ISO/IEC 5259, added as voluntary data governance references). Lawful basis section adds a Record of processing (ROPA) reference field, so each DPIA points to the Council's record of processing activities (UK GDPR Article 30). Proposed — for Council confirmation.	Data Protection Officer

NOT APPROVED — PROPOSED INTEGRATION ANNEX

Integration annex — DPIA and decision/evidence joins

DRAFT FOR COUNCIL REVIEW • 25 September 2026 • Not approved for operational use

Native assessment and legal roles

The DPIA remains the native data-protection assessment; the DPO's advice remains independent and the Controller/SRO retains the decision responsibility stated in the template. The integration does not determine whether Article 35, Article 22A–22D, a special-category restriction, or any other legal rule applies; record the DPO/Legal analysis and source in the DPIA.

AIR-ID, evidence and event pointers

Use an AIR-ID only after registration in AIG-INV-04. Keep DPIA content in this native record; cite each supporting source with its proposed AIG-INV-04 Evidence Index Evidence ID, source/version, observed or verified date, and location. Cite AIG-DEC-04 only by the ID and date of an actual Gate Event or Condition. An Article 36 consultation field is not evidence that consultation was required, completed, or had a particular outcome; any actual consultation evidence remains in its native record and may be indexed.

Decision, changes and contestability

Record the authorised processing decision and conditions in AIG-DEC-03 or authoritative forum minutes; an AIG-DEC-04 entry is a dated pointer, not the decision. Reflect approved/current state in AIG-INV-04 and post-deployment measures, changes, and reassessment in AIG-OPS-02. Reassess on material change in purpose, data, supplier, model/version, or processing. For individual representations, human intervention, review, or redress, link to the relevant AIG-OPS-04 route and preserve the case-level record there; do not infer that the route is operational from this cross-reference.

Fundamental-rights coverage: for how this DPIA contributes to EU AI Act Article 27 fundamental-rights impact assessment coverage, see the Fundamental Rights Coverage Crosswalk (AIG-ASS-12). The crosswalk is a design mapping, not case evidence.

Agent-enabled processing and draft status

If agentic actions or delegated access are in scope, link exact AIG-AGT-04 ASBOM permissions/version, use AIG-AGT-05 only as the derived authority view, and point to AIG-AGT-06 action records where relevant. These links do not authorise processing or actions. This proposed annex records no legal conclusion, DPIA outcome, consultation result, approval, or publication.

Standards and legal applicability — proposed QA cross-reference

PROPOSED QA INDEX — NOT APPROVED LEGAL ADVICE OR EVIDENCE OF COMPLIANCE. The listed instruments may be relevant to this artefact, but applicability depends on the case, service and Council delegation. Legislation, official guidance, Council policy and voluntary standards are different authority classes. The full 58-entry requirement inventory, authoritative URLs, validation owners and current versions are in AIG-AIMS-05; source checks are in AIG-AIMS-13. Do not treat a template, plan or cross-reference as completed assessment, adopted policy, ISO conformity or legal sign-off.

Requirement / instrument	Why check it here	Source
REQ-001 — UK General Data Protection Regulation (UK GDPR), as amended	Where personal data is processed; test each UK GDPR provision separately.	https://www.legislation.gov.uk/eur/2016/679/contents
REQ-002 — Data Protection Act 2018, as amended	Where DPA 2018 processing/rights rules are engaged; DPO to validate.	https://www.legislation.gov.uk/ukpga/2018/12/contents
REQ-003 — Data (Use and Access) Act 2025 (DUAA)	Where DUAA-amended UK GDPR/DPA provisions are engaged, including ADM safeguards.	https://ico.org.uk/about-the-ico/what-we-do/legislation-we-cover/data-use-and-access-act-2025/
REQ-056 — The Data Protection Act 2018 (Code of Practice on Artificial Intelligence and Automated Decision-Making) Regulations 2026 (SI 2026/425), and the ICO statutory code of practice on AI and automated decision-making that it requires	Where Council AI processes personal data or makes automated decisions; DPO to assess against the ICO code once issued; see AIG-AIMS-05 (REQ-056).	https://www.legislation.gov.uk/uksi/2026/425/made
REQ-033 — ICO Guidance on AI and Data Protection and AI Risk Toolkit	Screen the regulatory guidance requirement against this artefact's actual use and record evidence/version.	https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/